M365-15 · Data Classification & Handling

Four levels, applied to places rather than files — and the handling rules that follow from each. Written as a proposal for leadership to decide.

Field	Value
Document ID	M365-15
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	A. Microsoft 365
Operating tier	Tier 4 — IT Management. Classification is an organization decision that IT implements, not an IT decision.
Review cycle	Annually, and whenever a new regulated data type enters the organization.
Related existing policy	Your organization's information security policy, if it has one. If more than one copy exists, deciding which is authoritative is a prerequisite to publishing this document (§9).
Decision status	Written as the proposal that closes an open classification decision, rather than as a procedure waiting on one.

1. Purpose

Almost every rule in the Microsoft 365 domain — who may share what, with whom, for how long, and what happens when somebody leaves — has to answer the question “how sensitive is this?” A typical information security policy says sensitive data must be protected. What it usually lacks is a working scheme that tells a person which bucket the thing in front of them falls into.

Without that, every decision is made individually and inconsistently. A typical example: HR and IT work through payroll drive permissions during a file share retirement with no shared vocabulary for what payroll data requires. The conversation can be careful and go well; it still has to be had from first principles, and it will have to be had again for the next department.

> **This document is a proposal, not a procedure**
> Classification is an institutional decision with legal and regulatory implications. IT can propose a scheme and implement whatever is adopted; it cannot decide what the organization considers confidential.
> So section 3 is written to be argued with, and section 9 lists what must happen before it becomes binding. The purpose is to turn an open question into a decision executive leadership can actually take, rather than leaving a gap that blocks four other documents indefinitely.

2. The design choice that makes this work

> **Classify places, not files.**
>
> The conventional approach asks every person to label every document. In an organization with no dedicated records staff and a service desk already carrying a backlog, that will not happen — and a labelling scheme that is applied to a small fraction of documents is worse than none, because it creates the appearance of control.
>
> So classification attaches to the container: a SharePoint site, a document library, a shared mailbox, a Team. The site is classified once, by its owner, at the point it is created. Everything in it inherits that level.
>
> A person then never has to classify anything. They only have to put the thing in the right place — which is a question they can answer, and which M365-12 already asks them.

Three consequences follow, and all three are improvements:

- The decision is made once, by somebody who knows the department's work, rather than repeatedly by whoever happens to be saving a file.
- It is enforceable by configuration. Sharing restrictions, retention and access reviews can be applied to a site; they cannot realistically be applied to individually-labelled files at this scale.
- It makes the M365-10 site request the moment classification happens, which is exactly where a named owner is already being appointed. Individual file labelling stays available for the small number of documents that genuinely need to travel with their protection — a board paper, a legal document — but it is an exception, not the mechanism.

3. The four levels

Level	Means	Typical examples	If it got out
PUBLIC	Already published, or fit to be. No harm in disclosure.	Product or service catalogue. Press releases. Published policies. Published reports. Office locations and maps.	Nothing. It is already public.
INTERNAL	The working material of the organization. Not secret, not for publication. This is the default.	Meeting notes. Departmental procedures. Draft plans. Most email. Project documents. This catalogue.	Embarrassing rather than harmful. No notification obligation.
CONFIDENTIAL	Access on a need-to-know basis. Disclosure would harm an individual or the organization.	Customer and client records. Job applicant files. Personnel files and hiring records. Contracts. Budgets before publication. Conduct and disciplinary records. Donor or supporter records.	Real harm to a named person, contractual breach, or a privacy complaint. Likely to require notification.

Level	Means	Typical examples	If it got out
RESTRICTED	Small volume, tightly held, regulated. Disclosure is a reportable event.	Social security numbers. Payment card data. Health records (HIPAA). Credentials, keys and recovery keys. Anything under a breach-notification regime.	Regulatory exposure, statutory notification, and institutional consequence. Assume counsel is involved.

Four levels is a deliberate choice. Three is too coarse to separate “client records” from “social security numbers”, which have genuinely different handling. Five or more produces boundary arguments that consume more time than the distinction saves.

> **INTERNAL is the default, and that matters**
>
> A scheme whose default is CONFIDENTIAL sounds safer and is worse: everything becomes confidential, the label stops carrying information, and people route around it to get work done.
>
> Anything not deliberately classified is INTERNAL. That is a real level with real rules — it is simply not restrictive enough to obstruct ordinary work.

4. Which level is this? — the test

Work down. Stop at the first line that matches. This is the whole decision, and a site owner should be able to make it in under a minute.

	Does it contain...	Then
1	Social security numbers, payment card data, health information, or credentials and keys?	RESTRICTED
2	Anything the organization would have to notify a regulator or an individual about if it leaked?	RESTRICTED
3	Customer or client records protected by privacy law or contract — for example education, financial or legal records?	CONFIDENTIAL
4	Applicant, personnel, donor or conduct records about identifiable people?	CONFIDENTIAL
5	Contracts, unpublished budgets, or commercially sensitive material?	CONFIDENTIAL
6	Is it already published, or would the organization be content to publish it tomorrow?	PUBLIC
7	Anything else.	INTERNAL — the default, and most things

Where a site would contain a mix, it takes the highest level present. Where that makes the site unworkably restrictive, the answer is two sites rather than a compromise classification — and that is a useful signal that two different kinds of work were being stored together.

5. Handling rules

	PUBLIC	INTERNAL	CONFIDENTIAL	RESTRICTED
Who may access	Anyone	All staff by default	Named members only, approved by the site owner	A named, minimal list. Reviewed quarterly.
Sharing inside the organization	Free	Free	By the owner, to named people	By the owner, with Tier 4 aware
Sharing outside the organization	Free	Named guests, with a sponsor and expiry (M365-14)	Named guests only, expiry ≤ 90 days, owner and Tier 3 approval	Not by sharing. Use an agreed secure channel and record it.
“Anyone with the link”	Permitted	Discouraged	Prohibited	Prohibited
In email	Fine	Fine	Avoid — link to the site instead of attaching	Never as an attachment
In Teams chat	Fine	Fine	Link, do not upload	Never
On a personal device	Fine	Permitted per DEV-07	Only through managed apps, no local copies	Prohibited
Local copies on an organization device	Fine	Fine	Discouraged; the site is the record	Prohibited
Retention	As useful	Per M365-16	Per M365-16 and any records schedule	Per statute. Assume the longest.
On separation	No action	Per ACC-01 §7.3	Owner reviews access within 5 days	Access removed same day, and reviewed by Tier 4
Disposal	Delete	Delete	Per your sensitive-data disposal policy	Per that policy, with certificate

One rule cuts across all of them: link, do not copy. A link respects the site’s permissions and keeps one version; an attachment creates an uncontrolled copy that outlives every control on this page. It is also, usefully, the faster thing to do.

6. Where each level is allowed to live

Level	May live in	May not live in
PUBLIC	Anywhere, including the public website.	—
INTERNAL	Departmental SharePoint sites, Teams, mailboxes, personal OneDrive while genuinely a draft.	Nowhere prohibited, but see M365-12 — if the organization needs it after you leave, it belongs in a site.

Level	May live in	May not live in
CONFIDENTIAL	A SharePoint site classified CONFIDENTIAL, with a named owner. A shared mailbox with a named owner.	Personal OneDrive. An unclassified site. A Team created by self-service without a classification decision.
RESTRICTED	A site classified RESTRICTED with a minimal named membership, or the system of record itself — the HR and user system of record, the payroll system.	Personal OneDrive. Email attachments. Teams uploads. Any general departmental site. Any personal device.

The strongest single control here is the last row of the third column: RESTRICTED data mostly should not be in Microsoft 365 as documents at all. It should stay in the system of record. A payroll extract in a spreadsheet is a copy of something that was already safe.

7. Applying this during the file share retirement

> **Classify before you migrate, not after**
>
> When old network drives are retired, every folder on them lands somewhere. A retirement is therefore the single largest classification opportunity an organization gets, and the single largest risk of getting it wrong at scale.
>
> The order matters: classify the destination site, permission it, then move the content. Moving first and classifying later means the content sits in an unclassified place for however long “later” turns out to be.
>
> When HR asks what the retirement means for payroll access, this section is the answer: payroll content is CONFIDENTIAL at minimum, its destination site is classified and permissioned before anything moves, and access is by named membership approved by an HR owner rather than inherited from a drive letter.

M365-13 carries the migration runbook. This document supplies the classification step within it, and the two should be read together.

8. Worked examples

The thing	Level	What follows
This SOP catalogue	INTERNAL	Any staff member may read it. Publishable summaries are PUBLIC.
A front-desk shared mailbox	CONFIDENTIAL	Customer correspondence is about identifiable people. Named membership, owner-approved, temporary-worker access expiring at the end of the engagement (M365-03, ACC-09).
Payroll folders on an old network drive	CONFIDENTIAL, with RESTRICTED elements	Anything containing SSNs is RESTRICTED and should ideally stay in the payroll system rather than migrate as files.
A leadership handover site	CONFIDENTIAL	Contracts and financial records. Named membership; a handover belongs in a site rather than a shared OneDrive.
BitLocker recovery keys	RESTRICTED	Held in Entra, never copied into a ticket. Retrieval is verified and audited (DEV-03 §7).

The thing	Level	What follows
A departmental procedure document	INTERNAL	Departmental site. No special handling.
Staff conduct records	CONFIDENTIAL	Need-to-know. Not in a general HR site alongside INTERNAL material — separate site (§4).
An emergency action plan	PUBLIC or INTERNAL	An organization decision. If it is already on the staff intranet, it is INTERNAL at least.

9. What must happen before this is published

1. Where more than one copy of the information security policy exists, decide which is authoritative. Two copies of a security policy is itself a finding, and this document must extend one of them rather than float alongside both.
2. Executive leadership endorses the four levels in §3. Not the handling detail — the levels and what falls into each. That is the decision; everything else follows from it.
3. Confirm with counsel which regulated categories apply to the organization in practice: privacy law for the records it holds (e.g. HIPAA, FERPA, GDPR), PCI if it takes card payments, and the state breach-notification threshold. RESTRICTED is defined by that list.
4. Agree who classifies. This document proposes the site owner at the point of request, with Tier 4 confirming anything CONFIDENTIAL or above.
5. Decide whether existing sites are classified retrospectively or only at review. Retrospective is better and slower; the honest compromise is to classify at the next review and immediately for anything touched by the file share retirement.

> **What IT is asking for, in one sentence**
>
> Endorse four levels and who assigns them. IT will build the configuration, write the guidance, and classify the sites — but it cannot be the body that decides what the organization treats as confidential, and it should not be.

10. Records

Record	Held in	Retention
Classification of every site, with who set it and when	Site register (M365-10)	Life of the site
Executive leadership endorsement of §3	IT governance record	Permanent
Counsel advice on regulated categories	IT governance record	Permanent
Reclassification decisions	Site register + ticket	3 years
Exceptions granted	Tier 4 record	3 years

11. Related documents

ID	Title	Relationship
Info Sec Policy	Your organization's information security policy	This extends it. Where there are several copies, §9 step 1 settles which is authoritative.
Disposal Policy	Your organization's sensitive-data disposal policy	Governs the disposal row of §5.
M365-10	SharePoint Site Request, Provisioning & Ownership	Where classification is assigned — §2 depends on it entirely.
M365-11	SharePoint & OneDrive Permission Management	Implements the access rows of §5.
M365-13	Legacy File Share Retirement & Migration Runbook	§7. Classify before you migrate.
M365-14	External Sharing & Guest Access Governance	Implements the external-sharing rows of §5.
M365-12	OneDrive Appropriate Use	The boundary that keeps CONFIDENTIAL out of personal OneDrive.
M365-16	Retention, Legal Hold & eDiscovery	Retention rows of §5.
M365-03	Shared Mailbox Request & Ownership	Mailboxes are containers and are classified the same way.
ACC-17	Periodic Access Review	Quarterly review of RESTRICTED membership.
DEV-07	Personally-Owned Device Access Standard	The personal-device rows of §5.
GOV-03	Security Incident Response	What happens when a level is breached.

Appendix A — Handling matrix, one page

Print this. It is the whole scheme.

	PUBLIC	INTERNAL	CONFIDENTIAL	RESTRICTED
Lives in	Anywhere	Dept site, Teams, OneDrive drafts	Classified site, named members	Restricted site or system of record
Share inside	Free	Free	Owner approves, named people	Owner + Tier 4
Share outside	Free	Sponsored guest, expiry	Guest + owner + Tier 3, ≤90 days	Not by sharing
Anyone-with-link	OK	Avoid	No	No

	PUBLIC	INTERNAL	CONFIDENTIAL	RESTRICTED
Email attachment	OK	OK	Link instead	Never
Teams upload	OK	OK	Link instead	Never
Personal device	OK	Per DEV-07	Managed apps only	No
On separation	None	ACC-01 §7.3	Owner reviews in 5 days	Removed same day

Not sure? It is INTERNAL unless it contains identifiable people's records (CONFIDENTIAL) or SSNs, card data, health data or credentials (RESTRICTED).

Appendix B — Site owner's classification card

You are being asked to classify a site	You know what your department stores; IT does not. It is one decision, made once, and everything in the site inherits it.
The question	What is the most sensitive thing that will ever go in here?
Most sites are INTERNAL	Ordinary working material. No special handling. This is the right answer for the majority.
Choose CONFIDENTIAL if	It will hold records about identifiable people — clients, applicants, staff — or contracts and unpublished financials.
Choose RESTRICTED if	It will hold social security numbers, card payment data, health records or credentials. Talk to IT first; there may be a better home than a site.
If it is a mix	Ask for two sites rather than compromising. That is usually a sign two different kinds of work were being kept together.
What changes for you	CONFIDENTIAL and above means you approve who gets access, and you confirm the membership once a year. That is the whole obligation.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.